



INFORMATION PRIVACY ENGINEERING AND PRIVACY BY DESIGN

Understanding Privacy
Threats, Technology, and
Regulations Based on
Standards and
Best Practices



WILLIAM STALLINGS

Information Privacy Engineering and Privacy by Design

This page intentionally left blank

Information Privacy Engineering and Privacy by Design

**Understanding Privacy Threats,
Technology, and Regulations Based
on Standards and Best Practices**

Dr. William Stallings

◆◆ Addison-Wesley

Many of the designations used by manufacturers and sellers to distinguish their products are claimed as trademarks. Where those designations appear in this book, and the publisher was aware of a trademark claim, the designations have been printed with initial capital letters or in all capitals.

The author and publisher have taken care in the preparation of this book, but make no expressed or implied warranty of any kind and assume no responsibility for errors or omissions. No liability is assumed for incidental or consequential damages in connection with or arising out of the use of the information or programs contained herein.

“OASIS” and “PMRM” are trademarks of OASIS, the open standards consortium where the PMRM specification is owned and developed. PMRM is a copyrighted © work of OASIS Open. All rights reserved.

For information about buying this title in bulk quantities, or for special sales opportunities (which may include electronic versions; custom cover designs; and content particular to your business, training goals, marketing focus, or branding interests), please contact our corporate sales department at corpsales@pearsoned.com or (800) 382-3419.

For government sales inquiries, please contact governmentsales@pearsoned.com.

For questions about sales outside the U.S., please contact intlcs@pearson.com.

Visit us on the Web: informit.com/aw

Library of Congress Control Number: 2019952003

Copyright © 2020 Pearson Education, Inc.

All rights reserved. Printed in the United States of America. This publication is protected by copyright, and permission must be obtained from the publisher prior to any prohibited reproduction, storage in a retrieval system, or transmission in any form or by any means, electronic, mechanical, photocopying, recording, or likewise. For information regarding permissions, request forms and the appropriate contacts within the Pearson Education Global Rights & Permissions Department, please visit www.pearson.com/permissions/.

ISBN-13: 978-0-13-530215-6

ISBN-10: 0-13-530215-3

ScoutAutomatedPrintCode

Editor-in-Chief

Mark Taub

Product Line Manager

Brett Bartow

Development Editor

Christopher A. Cleveland

Managing Editor

Sandra Schroeder

Senior Project Editor

Lori Lyons

Copy Editor

Catherine D. Wilson

Production Manager

Gayathri Umashankaran/
codeMantra

Indexer

Tim Wright

Proofreader

Karen Davis

Technical Reviewers

Bruce DeBruhl

Stefan Schiffner

Editorial Assistant

Cindy Teeters

Cover Designer

Chuti Prasertsith

Compositor

codeMantra

To my loving and loyal wife, Tricia

This page intentionally left blank

Contents at a Glance

Preface	xxii
Part I Overview	1
Chapter 1: Security and Cryptography Concepts	2
Chapter 2: Information Privacy Concepts	32
Part II Privacy Requirements and Threats	53
Chapter 3: Information Privacy Requirements and Guidelines	54
Chapter 4: Information Privacy Threats and Vulnerabilities	94
Part III Technical Security Controls for Privacy	117
Chapter 5: System Access	118
Chapter 6: Malicious Software and Intruders	146
Part IV Privacy Enhancing Technologies	175
Chapter 7: Privacy in Databases	176
Chapter 8: Online Privacy	214
Chapter 9: Other PET Topics	258
Part V Information Privacy Management	293
Chapter 10: Information Privacy Governance and Management	294
Chapter 11: Risk Management and Privacy Impact Assessment	334
Chapter 12: Privacy Awareness, Training, and Education	374
Chapter 13: Event Monitoring, Auditing, and Incident Response	388
Part VI Legal and Regulatory Requirements	411
Chapter 14: The EU General Data Protection Regulation	412
Chapter 15: U.S. Privacy Laws	444
Index	472
Appendix (Online Only): Answers to Review Questions	

Table of Contents

Preface	xxii
Part I Overview	1
Chapter 1: Security and Cryptography Concepts	2
1.1 Cybersecurity, Information Security, and Network Security	2
Security Objectives	3
The Challenges of Information Security	5
1.2 Security Attacks	6
Passive Attacks	8
Active Attacks	8
1.3 Security Services	10
Authentication	10
Access Control	11
Data Confidentiality	11
Data Integrity	11
Nonrepudiation	12
Availability Service	12
1.4 Security Mechanisms	12
1.5 Cryptographic Algorithms	13
Keyless Algorithms	14
Single-Key Algorithms	14
Two-Key Algorithms	15
1.6 Symmetric Encryption	15
1.7 Asymmetric Encryption	17
1.8 Cryptographic Hash Functions	20
1.9 Digital Signatures	22
1.10 Practical Considerations	23
Selection of Cryptographic Algorithms and Key Lengths	23
Implementation Considerations	24

Lightweight Cryptographic Algorithms	24
Post-Quantum Cryptographic Algorithms	25
1.11 Public-Key Infrastructure.....	25
Public-Key Certificates	25
PKI Architecture	27
1.12 Network Security	29
Communications Security.....	29
Device Security	30
1.13 Key Terms and Review Questions.....	30
Key Terms	30
Review Questions	31
1.14 References	31
Chapter 2: Information Privacy Concepts	32
2.1 Key Privacy Terminology	32
2.2 Privacy by Design.....	35
Privacy by Design Principles.....	35
Requirements and Policy Development.....	37
Privacy Risk Assessment.....	37
Privacy and Security Control Selection	39
Privacy Program and Integration Plan	40
2.3 Privacy Engineering.....	41
Privacy Implementation	44
System Integration.....	44
Privacy Testing and Evaluation	45
Privacy Auditing and Incident Response	45
2.4 Privacy and Security.....	46
Areas of Overlap Between Security and Privacy	46
Trade-Offs Between Security and Privacy	48
2.5 Privacy Versus Utility	48

2.6	Usable Privacy.....	49
	Users of Privacy Services and Functions	50
	Usability and Utility	50
2.7	Key Terms and Review Questions.....	50
	Key Terms	50
	Review Questions	51
2.8	References	51
Part II Privacy Requirements and Threats		53
Chapter 3: Information Privacy Requirements and Guidelines		54
3.1	Personally Identifiable Information and Personal Data	55
	Sources of PII.....	57
	Sensitivity of PII	58
3.2	Personal Information That Is Not PII	59
3.3	Fair Information Practice Principles	63
3.4	Privacy Regulations.....	66
	European Union	66
	U.S. Privacy Laws and Regulations	67
3.5	Privacy Standards	68
	International Organization for Standardization (ISO).....	69
	National Institute of Standards and Technology	77
3.6	Privacy Best Practices	88
	Information Security Forum (ISF)	88
	Cloud Security Alliance (CSA).....	90
3.7	Key Terms and Review Questions.....	91
	Key Terms	91
	Review Questions	91
3.8	References	92

Chapter 4: Information Privacy Threats and Vulnerabilities	94
4.1 The Evolving Threat Environment.....	95
Overall Impact of Advances in Technology.....	95
Repurposing Collected Data.....	96
Means of Collection of PII.....	96
4.2 Privacy Threat Taxonomy	97
Information Collection.....	98
Information Processing	98
Information Dissemination	98
Invasions	99
4.3 NIST Threat Model	100
4.4 Threat Sources	105
4.5 Identifying Threats	106
4.6 Privacy Vulnerabilities.....	108
Vulnerability Categories	108
Location of Privacy Vulnerabilities	109
National Vulnerability Database and Common Vulnerability Scoring System	110
4.7 Key Terms and Review Questions.....	114
Key Terms	114
Review Questions	115
4.8 References	116
Part III Technical Security Controls for Privacy	117
Chapter 5: System Access	118
5.1 System Access Concepts	119
Privileges.....	119
System Access Functions.....	120
Privacy Considerations for System Access.....	121

5.2	Authorization	122
	Privacy Authorization	123
5.3	User Authentication	124
	Means of Authentication	125
	Multifactor Authentication.....	126
	A Model for Electronic User Authentication.....	127
5.4	Access Control	129
	Subjects, Objects, and Access Rights.....	130
	Access Control Policies	131
	Discretionary Access Control.....	131
	Role-Based Access Control.....	133
	Attribute-Based Access Control	135
5.5	Identity and Access Management	140
	IAM Architecture	140
	Federated Identity Management.....	142
5.6	Key Terms and Review Questions	144
	Key Terms	144
	Review Questions	145
5.7	Reference	145
Chapter 6: Malicious Software and Intruders		146
6.1	Malware Protection Activities	147
	Types of Malware	147
	The Nature of the Malware Threat	149
	Practical Malware Protection	150
6.2	Malware Protection Software	153
	Capabilities of Malware Protection Software.....	153
	Managing Malware Protection Software.....	154

6.3	Firewalls.....	155
	Firewall Characteristics.....	155
	Types of Firewalls.....	156
	Next-Generation Firewalls	163
	DMZ Networks.....	164
	The Modern IT Perimeter	165
6.4	Intrusion Detection	166
	Basic Intrusion Detection Principles	167
	Approaches to Intrusion Detection	167
	Host-Based Intrusion Detection Techniques	169
	Network-Based Intrusion Detection Systems.....	169
	IDS Best Practices	171
6.5	Key Terms and Review Questions.....	172
	Key Terms	172
	Review Questions	173
6.6	References	174
Part IV Privacy Enhancing Technologies		175
Chapter 7: Privacy in Databases		176
7.1	Basic Concepts	178
	Personal Data Attributes.....	179
	Types of Data Files.....	180
7.2	Re-Identification Attacks.....	183
	Types of Attacks.....	184
	Potential Attackers.....	186
	Disclosure Risks.....	186
	Applicability to Privacy Threats.....	187
7.3	De-Identification of Direct Identifiers.....	188
	Anonymization	189
	Pseudonymization.....	189

7.4	De-Identification of Quasi-Identifiers in Microdata Files	190
	Privacy-Preserving Data Publishing.....	192
	Disclosure Risk Versus Data Utility	193
	PPDP Techniques	194
7.5	<i>K</i> -Anonymity, <i>L</i> -Diversity, and <i>T</i> -Closeness	196
	<i>K</i> -Anonymity	196
	<i>L</i> -Diversity	198
	<i>T</i> -Closeness	199
7.6	Summary Table Protection	199
	Frequency Tables	200
	Magnitude Tables.....	203
7.7	Privacy in Queryable Databases	204
	Privacy Threats	205
	Protecting Queryable Databases	206
7.8	Key Terms and Review Questions	211
	Key Terms	211
	Review Questions	212
7.9	References	212
Chapter 8: Online Privacy		214
8.1	The Online Ecosystem for Personal Data.....	215
8.2	Web Security and Privacy	217
	Web Server Security and Privacy.....	218
	Web Application Security and Privacy	219
	Web Browser Security and Privacy.....	222
8.3	Mobile App Security	224
	Mobile Ecosystem.....	224
	Mobile Device Vulnerabilities	225
	BYOD Policies.....	227
	Mobile Application Vetting	229
	Resources for Mobile Device Security	230

8.4	Online Privacy Threats.....	231
	Web Application Privacy	231
	Mobile App Privacy	232
8.5	Online Privacy Requirements	234
	Online Privacy Principles	234
	Online Privacy Framework.....	236
	Simplified Consumer Choice	241
	Transparency of Data Practices	241
8.6	Privacy Notices.....	242
	Notice Requirements	243
	Notice Content.....	243
	Notice Structure	246
	Mobile App Privacy Notices.....	246
	Privacy Notice Design Space	248
8.7	Tracking	250
	Cookies	250
	Other Tracking Technologies.....	253
	Do Not Track	254
8.8	Key Terms and Review Questions	254
	Key Terms	254
	Review Questions	255
8.9	References	255
Chapter 9: Other PET Topics		258
9.1	Data Loss Prevention	258
	Data Classification and Identification	259
	Data States	260
	DLP for Email	262
	DLP Model	263

9.2	The Internet of Things	266
	Things on the Internet of Things	266
	Components of IoT-Enabled Things	266
	IoT and Cloud Context.....	267
9.3	IoT Security	270
	IoT Device Capabilities	270
	Security Challenges of the IoT Ecosystem	271
	IoT Security Objectives	273
9.4	IoT Privacy.....	274
	An IoT Model.....	275
	Privacy Engineering Objectives and Risks.....	276
	Challenges for Organizations.....	278
9.5	Cloud Computing	280
	Cloud Computing Elements.....	280
	Threats for Cloud Service Users	284
9.6	Cloud Privacy	285
	Data Collection	286
	Storage	287
	Sharing and Processing	290
	Deletion	290
9.7	Key Terms and Review Questions	290
	Key Terms	290
	Review Questions	291
9.8	References	291
Part V Information Privacy Management		293
Chapter 10: Information Privacy Governance and Management		294
10.1	Information Security Governance.....	295
	Information Security Management System.....	295
	Information Security Governance Concepts.....	295

Security Governance Components.....	298
Integration with Enterprise Architecture.....	303
Policies and Guidance	307
10.2 Information Privacy Governance	308
Information Privacy Roles	308
The Privacy Program Plan	312
10.3 Information Privacy Management	315
Key Areas of Privacy Management.....	316
Privacy Planning	317
Privacy Policy.....	319
10.4 OASIS Privacy Management Reference Model.....	322
Privacy Management Reference Model and Methodology (PMRM).....	322
Privacy by Design Documentation for Software Engineers	328
10.5 Key Terms and Review Questions.....	331
Key Terms	331
Review Questions	331
10.6 References	332
Chapter 11: Risk Management and Privacy Impact Assessment	334
11.1 Risk Assessment	335
Risk Assessment Process.....	335
Risk Assessment Challenges.....	339
Quantitative Risk Assessment	340
Qualitative Risk Assessment.....	342
11.2 Risk Management.....	346
NIST Risk Management Framework	347
ISO 27005: <i>Information Security Risk Management</i>	348
Risk Evaluation.....	351
Risk Treatment	352

11.3	Privacy Risk Assessment	353
	Privacy Impact	356
	Likelihood.....	361
	Assessing Privacy Risk	363
11.4	Privacy Impact Assessment	365
	Privacy Threshold Analysis	365
	Preparing for a PIA.....	366
	Identify PII Information Flows	367
	Identify Potential User Behavior	367
	Determine Relevant Privacy Safeguarding Requirements	368
	Assess Privacy Risk	368
	Determine Risk Treatment.....	368
	The PIA Report.....	369
	Implement Risk Treatment	370
	Review/Audit Implementation	370
	Examples	371
11.5	Key Terms and Review Questions.....	371
	Key Terms	371
	Review Questions	372
11.6	References	372
Chapter 12: Privacy Awareness, Training, and Education		374
12.1	Information Privacy Awareness	376
	Awareness Topics	377
	Awareness Program Communication Materials.....	378
	Awareness Program Evaluation	379
12.2	Privacy Training and Education	380
	Cybersecurity Essentials.....	380
	Role-Based Training.....	381
	Education and Certification	383

12.3	Acceptable Use Policies.....	384
	Information Security Acceptable Use Policy	384
	PII Acceptable Use Policy.....	386
12.4	Key Terms and Review Questions.....	386
	Key Terms	386
	Review Questions	387
12.5	References	387
Chapter 13: Event Monitoring, Auditing, and Incident Response		388
13.1	Event Monitoring	388
	Security Event Logging.....	389
	Security Event Management.....	391
	Event Logging Related to PII	392
13.2	Information Security Auditing	393
	Data to Collect for Auditing.....	394
	Internal and External Audits.....	395
	Security Audit Controls	396
13.3	Information Privacy Auditing	398
	Privacy Audit Checklist	398
	Privacy Controls.....	400
13.4	Privacy Incident Management and Response.....	401
	Objectives of Privacy Incident Management	401
	Privacy Incident Response Team.....	402
	Preparing for Privacy Incident Response	403
	Detection and Analysis	405
	Containment, Eradication, and Recovery	406
	Notification to Affected Individuals	407
	Post-Incident Activity.....	408

13.5	Key Terms and Review Questions	409
	Key Terms	409
	Review Questions	410
13.6	References	410
Part VI Legal and Regulatory Requirements		411
Chapter 14: The EU General Data Protection Regulation		412
14.1	Key Roles and Terms in the GDPR.....	413
14.2	Structure of the GDPR.....	415
14.3	GDPR Objectives and Scope	417
	Objectives	417
	Scope of the GDPR	418
14.4	GDPR Principles.....	420
	Fairness.....	421
	Lawful.....	422
	Transparency.....	423
14.5	Restrictions on Certain Types of Personal Data.....	423
	Children’s Personal Data.....	423
	Special Categories of Personal Data	424
14.6	Rights of the Data Subject	426
14.7	Controller, Processor, and Data Protection Officer	428
	Data Protection by Design and Default.....	428
	Records of Processing Activities	429
	Security of Processing	431
	Data Protection Officer	431
14.8	Data Protection Impact Assessment.....	433
	Risk and High Risk.....	433
	Determining Whether a DPIA Is Needed.....	434
	DPIA Process	436

GDPR Requirements.....	438
Criteria for an Acceptable DPIA.....	439
14.9 Key Terms and Review Questions.....	441
Key Terms	441
Review Questions	441
14.10 References	442
Chapter 15: U.S. Privacy Laws	444
15.1 A Survey of Federal U.S. Privacy Laws.....	445
15.2 Health Insurance Portability and Accountability Act	449
HIPAA Overview	449
HIPAA Privacy Rule.....	450
15.3 Health Information Technology for Economic and Clinical Health Act.....	456
Breach Notification	456
Encryption of PHI.....	457
Data Destruction	459
15.4 Children’s Online Privacy Protection Act.....	460
General Provisions	460
The COPPA Final Rule	461
15.5 California Consumer Privacy Act	462
Basic Concepts.....	462
Rights of Consumers	466
Comparison with the GDPR.....	468
15.6 Key Terms and Review Questions.....	470
Key Terms	470
Review Questions	470
15.7 References	471
Index	472
Appendix (Online Only): Answers to Review Questions	

Preface

Information privacy is the right of individuals to control or influence what information related to them may be collected, processed, and stored and by whom and to whom that information may be disclosed. In the context of information, the term *privacy* usually refers to ensuring that ostensibly private information about an individual is unavailable to parties that should not have that information.

Information privacy has become a high priority in all private and public organizations. Our society is being exposed to greater privacy threats and developing skills around Internet privacy, and safety is crucial to protecting our organizations and ourselves. The implementation of information privacy is the responsibility of IT organizations, specifically IT management, IT security management, and IT engineers. In addition, most organizations now have a senior privacy official or group to oversee compliance with privacy requirements. Typically, a chief privacy officer, data protection officer, or privacy leader fills this role.

Effective information privacy is very difficult. Increasingly, organizations have adopted an approach based on two concepts:

- **Privacy by design:** Encompasses management and technical means for including privacy considerations throughout the system development life cycle. The goal is to embed privacy in the design and architecture of IT systems and business practices.
- **Privacy engineering:** Encompasses the implementation, deployment, and ongoing operation and management of privacy features and controls in systems. Privacy engineering involves both technical capabilities and management processes.

Both standards documents, such as those issued by the International Organization for Standardization (ISO), and regulations, such as the European Union's General Data Protection Regulation (GDPR), mandate the use of privacy by design and privacy engineering.

The goal of this book is to present a comprehensive treatment of privacy by design and privacy engineering that will enable privacy executives and privacy engineers to manage and implement the privacy requirements dictated by standards, regulations, contractual commitments, and organizational policy.

Organization of the Book

The book consists of six parts:

- **Part I—Overview:** A necessary but insufficient aspect of information privacy is information security and the related field of cryptography; **Chapter 1** provides an overview of these concepts. Then, **Chapter 2** presents a survey of basic information privacy concepts, including privacy by design and privacy engineering.

- **Part II—Privacy Requirements and Threats:** **Chapter 3** discusses the requirements for information privacy that an organization must address. This discussion includes a definition of the types of personal data for which privacy is of concern, the concept of fair information practice principles, and the privacy regulations, standards, and best practices that drive the development of privacy solutions. Then, **Chapter 4** covers information privacy threats and the privacy vulnerabilities of information systems. Together, an understanding of requirements, threats, and vulnerabilities structure and guide privacy by design and privacy engineering solutions.
- **Part III—Technical Security Controls for Privacy:** There is considerable overlap between the requirements for information security and information privacy. Accordingly, privacy designers and engineers can select appropriate security controls to partially satisfy privacy requirements. Part Three examines in detail these security controls. **Chapter 5** looks at security controls for system access, which encompass the areas of authorization, user authentication, and access control. **Chapter 6** examines countermeasures to malicious software and to intruders.
- **Part IV—Privacy Enhancing Technologies:** Part Four examines technologies and practices that go beyond the traditional security controls in order to satisfy privacy requirements and counter privacy threats. **Chapter 7** discusses the complex issue of privacy in databases. Among the topics covered in this chapter are anonymization, de-identification, and privacy in queryable databases. **Chapter 8** provides a survey of threats, requirements, and approaches to online privacy. **Chapter 9** discusses the concept of data loss prevention and examines privacy issues related to cloud computing and the Internet of Things.
- **Part V—Information Privacy Management:** Part Five examines management and organizational privacy controls and procedures. **Chapter 10** discusses how information privacy governance enables the direction and oversight of information privacy–related activities across an enterprise, as an integrated part of corporate governance. The chapter also focuses on management issues related to information privacy. **Chapter 11** provides a detailed examination of one of the central tasks of information privacy management: privacy impact assessment. **Chapter 12** deals with the essential organizational task of developing a privacy culture based on organization-wide privacy awareness and the training and education of staff who have privacy-related duties. **Chapter 13** discusses techniques for auditing and monitoring the performance of privacy controls, with a view to spotting gaps in the system and devising improvements. The chapter also deals with planning for and reacting to threats through incident management.
- **Part VI—Legal and Regulatory Requirements:** **Chapter 14** provides a detailed examination of the EU’s General Data Protection Regulation, which is the most important privacy regulation that most organizations must deal with. **Chapter 15** surveys the key U.S. federal laws that relate to privacy and the California Consumer Privacy Act.

Supporting Websites

The author maintains a companion website at WilliamStallings.com/Privacy that includes a list of relevant links organized by chapter and an errata sheet for the book.

The author also maintains the Computer Science Student Resource Site, at ComputerScienceStudent.com. The purpose of this site is to provide documents, information, and links for computer science students and professionals. Links and documents are organized into seven categories:

- **Math:** Includes a basic math refresher, a queuing analysis primer, a number system primer, and links to numerous math sites.
- **How-to:** Advice and guidance for solving homework problems, writing technical reports, and preparing technical presentations.
- **Research resources:** Links to important collections of papers, technical reports, and bibliographies.
- **Other useful:** A variety of other useful documents and links.
- **Computer science careers:** Useful links and documents for those considering a career in computer science.
- **Writing help:** Help in becoming a clearer, more effective writer.
- **Miscellaneous topics and humor:** You have to take your mind off your work once in a while.



WilliamStallings.com/Privacy
Companion Website



computersciencestudent.com

Companion Book on Cybersecurity

I am also the author of *Effective Cybersecurity: A Guide to Using Best Practices and Standards* (Pearson, 2019). This book is addressed to people in both IT and security management, people tasked with maintaining IT security, and a wide range of others interested in cybersecurity and information security. The book enables privacy executives and engineers to gain a better grasp of the technical and management security practices that are essential elements in an information privacy program.



WilliamStallings.com/Cybersecurity
Companion Website

Register Your Book

Register your copy of *Information Privacy Engineering and Privacy by Design* on the InformIT site for convenient access to updates and/or corrections as they become available. To start the registration process, go to informit.com/register and log in or create an account. Enter the product ISBN (9780135302156) and click Submit. Look on the Registered Products tab for an Access Bonus Content link next to this product and follow that link to access any available bonus materials. If you would like to be notified of exclusive offers on new editions and updates, please check the box to receive email from us.

Acknowledgments

This book has benefited from review by a number of people, who gave generously of their time and expertise. I especially thank Bruce DeBruhl and Stefan Schiffner, who each devoted an enormous amount of time to a detailed review of the entire manuscript. I also thank the people who provided thoughtful reviews of the initial book proposal: Steven M. Bellovin, Kelley Dempsey, Charles A. Russell, Susan Sand, and Omar Santos.

Thanks also to the many people who provided detailed technical reviews of one or more chapters: Kavitha Ammayappan, Waleed Baig, Charlie Blanchard, Rodrigo Ristow Branco, Tom Cornelius, Shawn Davis, Tony Fleming, Musa Hussein, Pedro Inacio, Thomas Johnson, Mohammed B. M. Kamel, Rob Knox, Jolanda Modic, Omar Olivos, Paul E. Paray, Menaka Pushpa, Andrea Razzini, Antonius Ruslan, Ali Samouti, Neetesh Saxena, Javier H. Scodelaro, Massimiliano Sembiente, Abhijeet Singh, and Bill Woolsey.

Finally, I would like to thank the many people at Pearson responsible for the publication of the book. This includes the staff at Pearson, particularly Brett Bartow (director of IT Professional Product Management), Chris Cleveland (development editor), Lori Lyons (senior project editor), Gayathri Umashankaran (production manager), and Kitty Wilson (copyeditor). Thanks also to the marketing and sales staffs at Pearson, without whose efforts this book would not be in front of you.

About the Author

Dr. William Stallings has made a unique contribution to understanding the broad sweep of technical developments in computer security, computer networking, and computer architecture. He has authored 18 textbooks, and, counting revised editions, a total of 70 books on various aspects of these subjects. His writings have appeared in numerous ACM and IEEE publications, including the *Proceedings of the IEEE* and *ACM Computing Reviews*. He has 13 times received the award for the best computer science textbook of the year from the Text and Academic Authors Association.

With more than 30 years in the field, he has been a technical contributor, a technical manager, and an executive with several high-technology firms. He has designed and implemented both TCP/IP-based and OSI-based protocol suites on a variety of computers and operating systems, ranging from micro-computers to mainframes. Currently he is an independent consultant whose clients have included computer and networking manufacturers and customers, software development firms, and leading-edge government research institutions.

He created and maintains the Computer Science Student Resource Site, at computersciencestudent.com. This site provides documents and links on a variety of subjects of general interest to computer science students and professionals.

He is a member of the editorial board of *Cryptologia*, a scholarly journal devoted to all aspects of cryptography.

Dr. Stallings holds a PhD from M.I.T. in Computer Science and a B.S. from Notre Dame in electrical engineering.

Figure Credits

Figure	Attribution/Credit Line
Cover	art_of_sun/Shutterstock; dboystudio/ Shutterstock
FIG01-09a	Iconic Bestiary/Shutterstock
FIG04-01a	cheskyw/123RF
FIG04-05a.1	Sashkin/Shutterstock
FIG04-05a.2	Sashkin/Shutterstock
FIG04-05a.3	Sashkin/Shutterstock
FIG04-05b.1	Jojje/Shutterstock
FIG04-05b.2	Jojje/Shutterstock
FIG04-05b.3	Jojje/Shutterstock
FIG04-05b.4	Jojje/Shutterstock
FIG05-01a	Ganna Rassadnikova/123RF
FIG05-01b	ostapenko/123RF
FIG05-01c	arturaliev/123RF
FIG05-01d	Jojje/Shutterstock
FIG05-01e	Sashkin/Shutterstock
FIG05-02a	Dmitry Rukhlenko/Shutterstock
FIG05-02b	Dmitry Rukhlenko/Shutterstock
FIG05-06a	arturaliev/123RF
FIG05-06b	Lightwave Stock Media/123RF
FIG05-07a	ostapenko/123RF
FIG05-08a	ostapenko/123RF
FIG05-08b.1	Sashkin/Shutterstock
FIG05-08b.2	Sashkin/Shutterstock
FIG06-01a	Arvind Singh Negi/Red Reef Design Studio/Pearson India Education Services Pvt. Ltd
FIG06-01b	DR Travel Photo and Video/Shutterstock
FIG06-01c	Oleksandr_Delyk/Shutterstock
FIG06-01d	Sashkin/Shutterstock
FIG06-01e	yukipon/123RF

FIG06-01f	Robert Milek/Shutterstock
FIG06-02a	dny3d/Shutterstock
FIG06-03a	Oleksandr_Delyk/Shutterstock
FIG06-03b.1	Sashkin/Shutterstock
FIG06-03b.2	Sashkin/Shutterstock
FIG06-03b.3	Sashkin/Shutterstock
FIG06-03b.4	Sashkin/Shutterstock
FIG06-03b.5	Sashkin/Shutterstock
FIG06-03b.6	Sashkin/Shutterstock
FIG06-03C.1	dny3d/Shutterstock
FIG06-03C.2	dny3d/Shutterstock
FIG06-03d.1	Sebastian Kaulitzki/Shutterstock
FIG06-03d.2	Sebastian Kaulitzki/Shutterstock
FIG06-03d.3	Sebastian Kaulitzki/Shutterstock
FIG06-06a	DR Travel Photo and Video/Shutterstock
FIG06-06b.1	Oleksandr_Delyk/Shutterstock
FIG06-06b.2	Oleksandr_Delyk/Shutterstock
FIG06-06b.3	Oleksandr_Delyk/Shutterstock
FIG06-06b.4	Oleksandr_Delyk/Shutterstock
FIG06-06c.1	Sashkin/Shutterstock
FIG06-06c.2	Sashkin/Shutterstock
FIG06-06c.3	Sashkin/Shutterstock
FIG06-06d.1	dny3d/Shutterstock
FIG06-06d.2	dny3d/Shutterstock
FIG06-06d.3	dny3d/Shutterstock
FIG07-01a	Arcady/Shutterstock
FIG07-01b	fzd.it/Shutterstock
FIG07-02a	ammentorp/123RF
FIG07-04a	ASDF_MEDIA/Shutterstock
FIG07-04b	lawyerphoto/Shutterstock
FIG08-02a.1	Oleksandr_Delyk/Shutterstock
FIG08-02a.2	Oleksandr_Delyk/Shutterstock

FIG08-02a.3	Oleksandr_Delyk/Shutterstock
FIG08-02b.1	DR Travel Photo and Video/Shutterstock
FIG08-02b.2	DR Travel Photo and Video/Shutterstock
FIG08-02c.1	dny3d/Shutterstock
FIG08-02c.2	dny3d/Shutterstock
FIG08-02c.3	dny3d/Shutterstock
FIG08-02d	Sashkin/Shutterstock
FIG08-02e	Alex Mit/Shutterstock
FIG08-03a	yukipon/123RF
FIG08-03b	mipan/Shutterstock
FIG08-03c.1	Jojje/Shutterstock
FIG08-03c.2	Jojje/Shutterstock
FIG08-03c.3	Jojje/Shutterstock
FIG08-03c.4	Jojje/Shutterstock
FIG08-03c.5	Jojje/Shutterstock
FIG08-03c.6	Jojje/Shutterstock
FIG08-03c.7	Jojje/Shutterstock
FIG08-03c.8	Jojje/Shutterstock
FIG08-03d	dny3d/Shutterstock
FIG08-04a	Scott Betts/123RF
FIG09-06a.1	Milos Luzanin/Shutterstock
FIG09-06a.2	Milos Luzanin/Shutterstock
FIG09-10a	Iconic Bestiary/Shutterstock
FIG10-01a	maxuser/Shutterstock
FIG10-01b	David Franklin/123RF
FIG10-01c	Pavel L Photo and Video/Shutterstock
Table 10-6	Copyright © OASIS Open 2016. All Rights Reserved.
FIG13-01a	Sebastian Kaulitzki/Shutterstock

PART I

Overview

Chapter 1

Security and Cryptography Concepts

Learning Objectives

After studying this chapter, you should be able to:

- Describe the five main security objectives
- Explain the main uses of cryptography
- Describe four types of cryptographic algorithms
- Understand the concept of public-key infrastructure

Essential to understanding the concept of information privacy is an understanding of information security. As described in Chapter 2, “Information Privacy Concepts,” there are areas of overlap as well as areas of nonoverlap between these two fields. This book provides numerous examples of privacy management, design, and technology concepts that require the use of the corresponding security concepts. This chapter provides a brief overview of information security concepts in Sections 1.1 through 1.4. Then, Sections 1.5 through 1.10 survey important aspects and implications of cryptography, which is the fundamental technology underlying much of information security. Then, Section 1.11 introduces the important topic of public-key infrastructure. Finally, Section 1.12 provides an introduction to network security.

1.1 Cybersecurity, Information Security, and Network Security

It is useful to start this chapter with a definition of the terms *cybersecurity*, *information security*, and *network security*. A reasonably comprehensive definition of **cybersecurity** based on one in NISTIR (Small Business Information Security: The Fundamentals, 2016) follows:

Cybersecurity is the prevention of damage to, unauthorized use of, exploitation of, and—if needed—the restoration of electronic information and communications systems, electronic communications services, wire communication, and electronic communication, including information contained therein, to ensure its availability, integrity, authentication, confidentiality, and nonrepudiation.

As subsets of cybersecurity, we can define the following:

- **Information security:** Preservation of confidentiality, integrity, and availability of information. In addition, other properties, such as authenticity, accountability, nonrepudiation, and reliability, can also be involved.
- **Network security:** Protection of networks and their services from unauthorized modification, destruction, or disclosure and provision of assurance that the networks perform their critical functions correctly, without harmful side effects.

Cybersecurity encompasses information security, with respect to electronic information, and network security. Information security also is concerned with physical (e.g., paper-based) information. However, in practice, the terms *cybersecurity* and *information security* are often used interchangeably.

Security Objectives

The cybersecurity definition just given introduces three key objectives that are at the heart of information and network security:

- **Confidentiality:** Also known as *data confidentiality*, the property that information is not made available or disclosed to unauthorized individuals, entities, or processes. A loss of confidentiality is the unauthorized disclosure of information.
- **Integrity:** This term covers two related concepts:
 - **Data integrity:** Ensures that data (both stored and in transmitted packets) and programs are changed only in a specified and authorized manner. A loss of data integrity is the unauthorized modification or destruction of information.
 - **System integrity:** Ensures that a system performs its intended function in an unimpaired manner, free from deliberate or inadvertent unauthorized manipulation of the system.
- **Availability:** Ensures that systems work promptly and that service is not denied to authorized users. A loss of availability is the disruption of access to or use of information or an information system.

Note

We can define *information* as communication or representation of knowledge such as facts, data, or opinions in any medium or form, including textual, numerical, graphic, cartographic, narrative, or audiovisual; and *data* as information with a specific representation that can be produced, processed, or stored by a computer. Security literature typically does not make much of a distinction between the two, nor does this book.

These three concepts form what is often referred to as the *CIA triad*. These three concepts embody the fundamental security objectives for both data and information and computing services. For example, the NIST (National Institute of Standards and Technology) standard FIPS 199 (*Standards for Security Categorization of Federal Information and Information Systems*) lists confidentiality, integrity, and availability as the three security objectives for information and for information systems.

Although the use of the CIA triad to define security objectives is well established, many in the security field feel that additional concepts are needed to present a complete picture, as illustrated in Figure 1.1. The list that follows describes two of the most commonly mentioned additional security concepts:

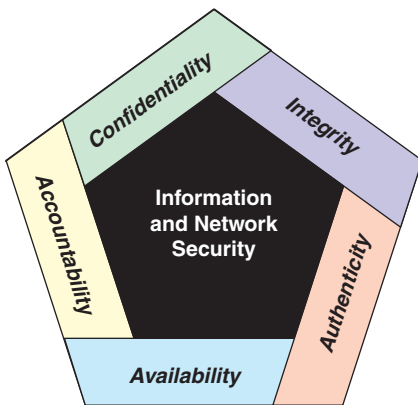


FIGURE 1.1 Essential Information and Network Security Objectives

- **Authenticity:** The property of being genuine and being able to be verified and trusted; confidence in the validity of a transmission, a message, or a message originator. This means verifying that users are who they say they are and that each input arriving at the system came from a trusted source.
- **Accountability:** The security goal that generates the requirement for actions of an entity to be traced uniquely to that entity. This supports nonrepudiation, deterrence, fault isolation,

intrusion detection and prevention, and after-action recovery and legal action. Because truly secure systems are not yet an achievable goal, it must be possible to trace a security breach to a responsible party. Systems must keep records of their activities to permit later forensic analysis to trace security breaches or to aid in transaction disputes.

The Challenges of Information Security

Information and network security are both fascinating and complex. Some of the reasons follow:

1. Security is not as simple as it might first appear to the novice. The requirements seem to be straightforward; indeed, most of the major requirements for security services can be given self-explanatory, one-word labels: confidentiality, authentication, nonrepudiation, integrity. But the mechanisms used to meet those requirements can be quite complex, and understanding them may involve rather subtle reasoning.
2. In developing a particular security mechanism or algorithm, designers must always consider potential attacks on those security features. In many cases, successful attacks are designed by looking at the problem in a completely different way and exploiting an unexpected weakness in the mechanism.
3. Because of point 2, the procedures used to provide particular services are often counterintuitive. Typically, a security mechanism is complex, and it is not obvious from the statement of a particular requirement that such elaborate measures are needed. It is only when the various aspects of the threat are considered that elaborate security mechanisms make sense.
4. Having designed various security mechanisms, it is necessary to decide where to use them. This is true both in terms of physical placement (e.g., at what points in a network are certain security mechanisms needed?) and in a logical sense (e.g., should containers or virtual machines be used to isolate personal information, or should an integrated access control mechanism be used to protect all types of data, with access determined by user roles and privileges?).
5. Security mechanisms typically involve more than a particular algorithm or protocol. They also require that participants be in possession of some secret information (e.g., an encryption key), which raises questions about the creation, distribution, and protection of that secret information. There also may be a reliance on communications protocols, whose behavior may complicate the task of developing the security mechanism. For example, if the proper functioning of a security mechanism requires setting time limits on the transit time of a message from sender to receiver, then any protocol or network that introduces variable, unpredictable delays might render such time limits meaningless. It is worth mentioning here that security mechanisms are generally not secret, and indeed they may be open source, but secrecy is provided by maintaining the security of encryption keys, as discussed subsequently.

6. Information and network security are essentially a battle of wits between a perpetrator who tries to find holes and a designer or an administrator who tries to close them. The great advantage that the attacker has is that he or she need find only a single weakness, while the designer must find and eliminate all weaknesses to achieve perfect security.
7. There is a natural tendency on the part of users and system managers to perceive little benefit from security investment until a security failure occurs.
8. Security requires regular, even constant, monitoring, and this is difficult in today's short-term, overloaded environment.
9. Security is still too often an afterthought to be incorporated into a system after the design is complete rather than being an integral part of the design process.
10. Many users and even security administrators view strong security as an impediment to efficient and user-friendly operation of an information system or use of information.

These difficulties apply equally as well to information privacy. The difficulties just enumerated will be encountered in numerous ways as we examine the various privacy threats and mechanisms throughout this book.

1.2 Security Attacks

ITU-T Recommendation X.800 (*Security Architecture for Open Systems Interconnection [OSI]*) defines a general security architecture that is useful to managers as a way of organizing the task of providing security. The OSI security architecture focuses on security attacks, mechanisms, and services. These can be defined briefly as follows:

- **Security attack:** Any action that compromises the security of information owned by an organization.
- **Security mechanism:** A process (or a device incorporating such a process) that is designed to detect, prevent, or recover from a security attack.
- **Security service:** A processing or communication service that enhances the security of the data processing systems and the information transfers of an organization. Security services are intended to counter security attacks, and they make use of one or more security mechanisms to provide the services.

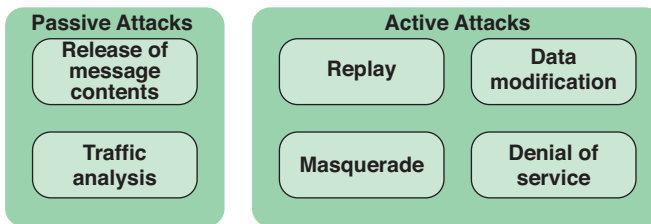
In the literature, the terms *threat* and *attack* are commonly used, with the following meanings:

- **Threat:** Any circumstance or event that has the potential to adversely impact organizational operations (including mission, functions, image, or reputation), organizational assets,

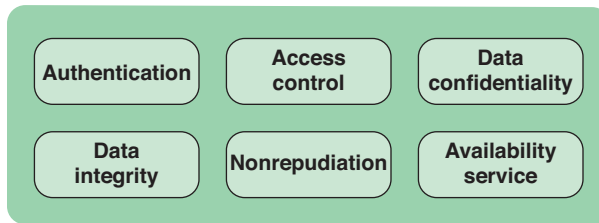
individuals, other organizations, or the nation through an information system via unauthorized access, destruction, disclosure, modification of information, and/or denial of service.

- **Attack:** Any kind of malicious activity that attempts to collect, disrupt, deny, degrade, or destroy information system resources or the information itself.

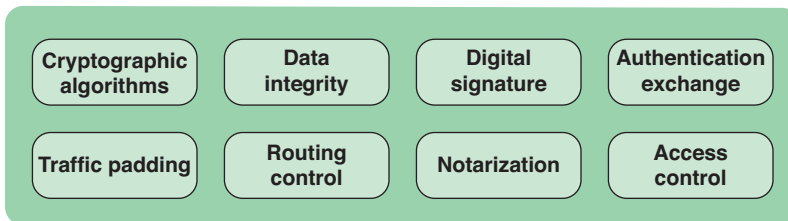
Sections 1.2 through 1.4 provide an overview of the concepts of attacks, services, and mechanisms. The key concepts that are covered in these sections are summarized in Figure 1.2.



(a) Attacks



(b) Services



(c) Mechanisms

FIGURE 1.2 Key Concepts in Security

X.800 classifies security attacks as either *passive attacks* or *active attacks*. A passive attack attempts to learn or make use of information from the system but does not affect system resources. An active attack attempts to alter system resources or affect their operation.

Passive Attacks

Passive attacks are in the nature of eavesdropping on, or monitoring of, transmissions. The goal of the attacker is to obtain information that is being transmitted. Two types of passive attacks are the release of message contents and traffic analysis:

- **Release of message contents:** The act of an adversary in successfully eavesdropping on a communication, such as a telephone conversation, an electronic mail message, or a transferred file.
- **Traffic analysis:** A form of attack in which the contents of transmitted data blocks are not examined. Assume that there was a way of masking the contents of messages or other information traffic so that adversaries, even if they captured the message, could not extract the information from the message. The common technique for masking contents is encryption. With encryption protection in place, an adversary might still be able to observe the pattern of these messages. The adversary could determine the location and identity of communicating hosts and could observe the frequency and length of messages being exchanged. This information might be useful in guessing the nature of the communication that was taking place.

Passive attacks are very difficult to detect because they do not involve any alteration of the data. Typically, the message traffic is sent and received in an apparently normal fashion, and neither the sender nor the receiver is aware that a third party has read the messages or observed the traffic pattern. However, it is possible to prevent the success of these attacks, usually by means of encryption. Thus, the emphasis in dealing with passive attacks is on prevention rather than detection.

Active Attacks

Active attacks involve some modification of stored or transmitted data or the creation of false data. There are four categories of active attacks: replay, masquerade, modification of messages, and denial of service.

- A *masquerade* takes place when one entity pretends to be a different entity. A masquerade attack usually includes one of the other forms of active attack. For example, authentication sequences can be captured and replayed after a valid authentication sequence has taken place, thus enabling an authorized entity with few privileges to obtain extra privileges by impersonating an entity that has those privileges.
- **Replay** involves the passive capture of a data unit and its subsequent retransmission to produce an unauthorized effect.
- **Data modification** simply means that some portion of a legitimate message is altered or that messages are delayed or reordered to produce an unauthorized effect. For example, a message stating “Allow John Smith to read confidential file Accounts” might be modified to say “Allow Fred Brown to read confidential file Accounts.”

- A **denial-of-service attack** prevents or inhibits the normal use or management of communication facilities. Such an attack may have a specific target; for example, an entity may suppress all messages directed to a particular destination (e.g., the security audit service). Another form of service denial is the disruption of an entire network, either by disabling the network or by overloading it with messages so as to degrade performance.

Active attacks present the opposite characteristics of passive attacks. Whereas passive attacks are difficult to detect, measures are available to prevent their success. On the other hand, it is quite difficult to prevent active attacks absolutely because to do so would require physical protection of all IT systems, communication facilities, and paths at all times. Instead, the goal is to detect them and to recover from any disruption or delays caused by them. Because detection has a deterrent effect, it may also contribute to prevention.

Figure 1.3 illustrates the types of attacks in the context of a client/server interaction. A passive attack (part b of Figure 1.3) does not disturb the information flow between the client and server but is able to observe that flow.

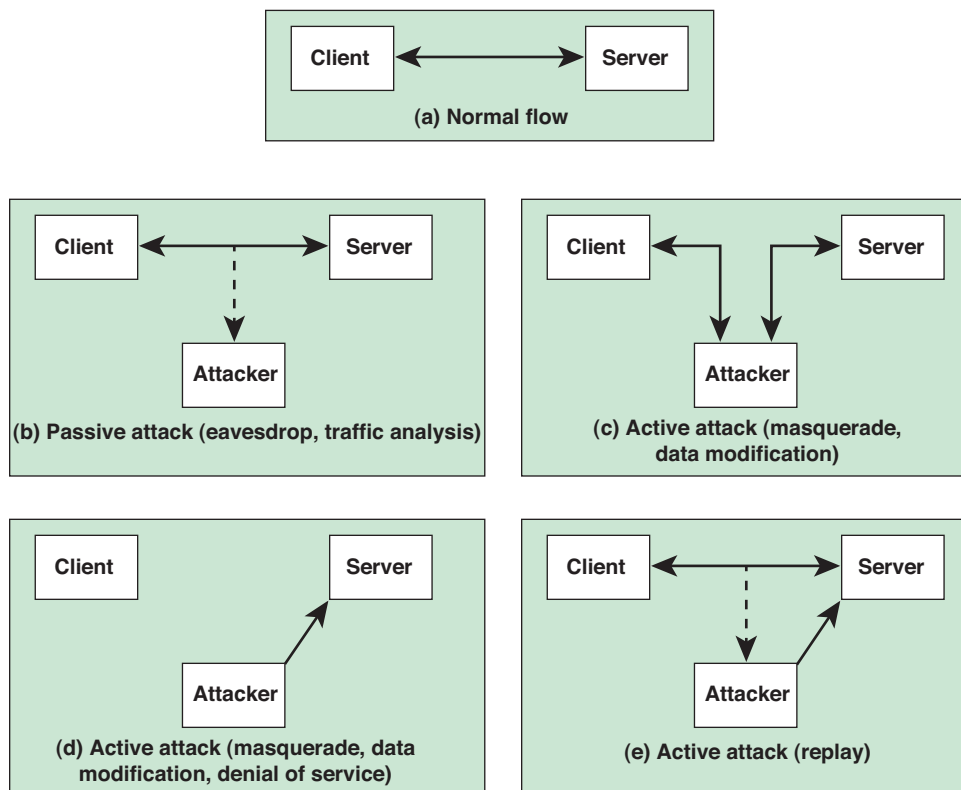


FIGURE 1.3 Security Attacks

A masquerade can take the form of a man-in-the-middle attack (see part c of Figure 1.3). In this type of attack, the attacker intercepts masquerades as the client to the server and as the server to the client. Another form of masquerade is illustrated in part d of Figure 1.3. Here, an attacker is able to access server resources by masquerading as an authorized user.

Data modification may involve a man-in-the middle attack, in which the attacker selectively modifies communicated data between a client and server (see part c of Figure 1.3). Another form of data modification attack is the modification of data residing on a server or another system after an attacker gains unauthorized access (see part d of Figure 1.3).

Part e of Figure 1.3 illustrates the replay attack. As in a passive attack, the attacker does not disturb the information flow between client and server but does capture client messages. The attacker can then subsequently replay any client message to the server.

Part d of Figure 1.3 also illustrates denial of service in the context of a client/server environment. The denial of service can take two forms: (1) flooding the server with an overwhelming amount of data and (2) triggering some action on the server that consumes substantial computing resources.

1.3 **Security Services**

A security service is a capability that supports one or more of the security requirements (confidentiality, integrity, availability, authenticity, accountability). Security services implement security policies and are implemented by security mechanisms.

The most important security services are shown in part b of Figure 1.2 and summarized in Table 1.1.

TABLE 1.1 Security Services

Service	Description
Authentication	A person's identity is determined before access is granted.
Access Control	Persons are allowed or denied access to resources for specific purposes.
Data Confidentiality	Information is only available to persons intended to use or see it.
Data Integrity	Information is modified only in appropriate ways by persons authorized to change it.
Nonrepudiation	A person cannot perform an action and then later deny performing the action.
Availability	Apps, services, and hardware are ready when needed and perform acceptably.

Authentication

The authentication service is concerned with ensuring that a communication is authentic. In the case of a single message, such as a warning or an alarm signal, the function of the authentication service is to ensure the recipient that the message is from the source that it claims to be from. In the case of an ongoing interaction, such as the connection of a client to a server, two aspects are involved. First, at the time of connection initiation, the service ensures that the two entities are authentic—that is, that each is the entity that it claims to be. Second, the service must ensure that the connection is not interfered with

in such a way that a third party can masquerade as one of the two legitimate parties for the purpose of unauthorized transmission or reception.

X.800 defines two specific authentication services:

- **Peer entity authentication:** Provides for the corroboration of the identity of a peer entity in an association. Two entities are considered peers if they implement the same protocol in different systems. Peer entity authentication is provided for use at the establishment of, or at times during the data transfer phase of, a connection. It attempts to provide confidence that an entity is not performing either a masquerade or an unauthorized replay of a previous connection.
- **Data origin authentication:** Provides for the corroboration of the source of a data unit. It does not provide protection against the duplication or modification of data units. This type of service supports applications like electronic mail, where there are no ongoing interactions between the communicating entities.

Access Control

Access control is the ability to limit and control the access to host systems and applications via communications links. To achieve this, each entity trying to gain access must first be identified, or authenticated, so that access rights can be tailored to the individual.

Data Confidentiality

Confidentiality is the protection of transmitted data from passive attacks. With respect to the content of a data transmission, several levels of protection can be identified. The broadest service protects all user data transmitted between two users over a period of time. For example, when a logical network connection is set up between two systems, this broad protection prevents the release of any user data transmitted over the connection.

The other aspect of confidentiality is the protection of traffic flow from analysis. This requires that an attacker not be able to observe the source and destination, frequency, length, or other characteristics of the traffic on a communications facility.

Data Integrity

A connection-oriented integrity service—one that deals with a stream of messages—ensures that messages are received as sent, with no duplication, insertion, modification, reordering, or replays. The destruction of data is also covered under this service. Thus, the connection-oriented integrity service addresses both message stream modification and denial of service. On the other hand, a connectionless integrity service—one that deals with individual messages without regard to any larger context—generally provides protection against message modification only.

We can make a distinction between service with and without recovery. Because the integrity service relates to active attacks, we are concerned with detection rather than prevention. If a violation of integrity is detected, then the service may simply report this violation, and some other portion of software or human intervention is required to recover from the violation. Alternatively, there are mechanisms available to recover from the loss of integrity of data, as we will review subsequently. The incorporation of automated recovery mechanisms is, in general, the more attractive alternative.

Nonrepudiation

Nonrepudiation prevents either a sender or a receiver from denying a transmitted message. Thus, when a message is sent, the receiver can prove that the alleged sender in fact sent the message. Similarly, when a message is received, the sender can prove that the alleged receiver in fact received the message.

Availability Service

Availability means that a system or a system resource is accessible and usable upon demand by an authorized system entity, according to performance specifications for the system; that is, a system is available if it provides services according to the system design whenever users request them. A variety of attacks can result in loss of or reduction in availability. Some of these attacks are amenable to automated countermeasures, such as authentication and encryption, whereas others require some sort of physical action to prevent or recover from loss of availability of elements of a distributed system.

X.800 treats availability as a property to be associated with various security services. However, it makes sense to call out specifically an availability service—that is, a service that protects a system to ensure its availability. This service addresses the security concerns raised by denial-of-service attacks. It depends on proper management and control of system resources and thus depends on access control service and other security services.

1.4 Security Mechanisms

Part b of Figure 1.2 lists the most important security mechanisms, which include:

- **Cryptographic algorithms:** Sections 1.5 through 1.9 cover this topic.
- **Data integrity:** This category covers a variety of mechanisms used to ensure the integrity of a data unit or stream of data units.
- **Digital signature:** Data appended to, or a cryptographic transformation of, a data unit that allows a recipient of the data unit to prove the source and integrity of the data unit and protect against forgery.
- **Authentication exchange:** A mechanism intended to ensure the identity of an entity by means of information exchange.
- **Traffic padding:** The insertion of bits into gaps in a data stream to frustrate traffic analysis attempts.

- **Routing control:** A control that enables selection of particular physically or logically secure routes for certain data and allows routing changes, especially when a breach of security is suspected.
- **Notarization:** The use of a trusted third party to ensure certain properties of a data exchange.
- **Access control:** A variety of mechanisms that enforce access rights to resources.

1.5 Cryptographic Algorithms

The NIST Computer Security Glossary (<https://csrc.nist.gov/glossary>) provides the following definitions:

Cryptography: 1. The discipline that embodies the principles, means, and methods for the transformation of data in order to hide their semantic content, prevent their unauthorized use, or prevent their undetected modification. 2. The discipline that embodies the principles, means, and methods for the providing information security, including confidentiality, data integrity, non-repudiation, and authenticity.

Cryptographic algorithm: A well-defined computational procedure, pertaining to cryptography, that takes variable inputs, often including a cryptographic key, and produces an output.

Cryptography is an essential component in the secure storage and transmission of data and in the secure interaction between parties. Sections 1.5 through 1.10 provide brief technical introductions to important aspects of the use of cryptography and cryptographic algorithms. For a more detailed treatment, see *Cryptography and Network Security: Principles and Practice* [STAL20].

Cryptographic algorithms can be divided into three categories, as illustrated in Figure 1.4 and described in the list that follows:

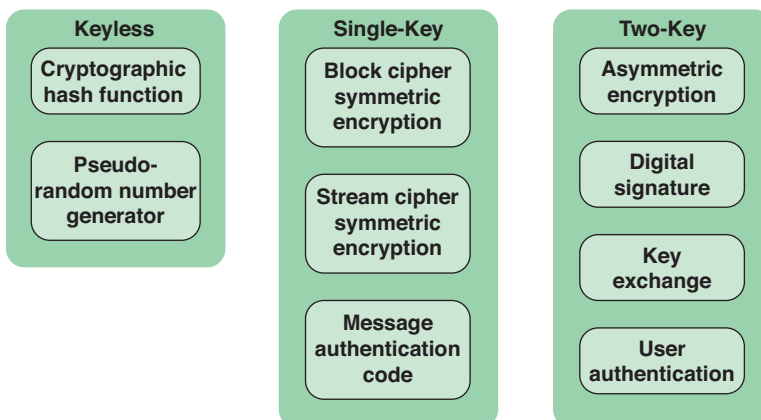


FIGURE 1.4 Cryptographic Algorithms

- **Keyless:** An algorithm that does not use any keys during cryptographic transformations.
- **Single-key:** An algorithm in which the result of a transformation is a function of the input data and a single key, known as a secret key.
- **Two-key:** An algorithm in which, at various stages of the calculation, two different but related keys are used, referred to as the private key and the public key.

Keyless Algorithms

Keyless algorithms are deterministic functions that have certain properties that are useful for cryptography.

One important type of keyless algorithm is the cryptographic hash function. A hash function turns a variable amount of text into a small, fixed-length value called a *hash value*, *hash code*, or *digest*. A **cryptographic hash function** has additional properties that make it useful as part of another cryptographic algorithm, such as a message authentication code or a digital signature.

A **pseudorandom number generator** produces a deterministic sequence of numbers or bits that has the appearance of being a truly random sequence. Although the sequence appears to lack any definite pattern, it will repeat after a certain sequence length. Nevertheless, for some cryptographic purposes, this apparently random sequence is sufficient.

Single-Key Algorithms

Single-key cryptographic algorithms depend on the use of a secret key. This key may be known to a single user; for example, this is the case when protecting stored data that is only going to be accessed by the data creator. Commonly, two parties share the secret key so that communication between the two parties is protected. For certain applications, more than two users may share the same secret key. In this case, the algorithm protects data from those outside the group who share the key.

Encryption algorithms that use a single key are referred to as **symmetric encryption algorithms**. With symmetric encryption, an encryption algorithm takes as input some data to be protected and a secret key and produces an unintelligible transformation on that data. A corresponding decryption algorithm uses the transformed data and the same secret key to recover the original data.

Another form of single-key cryptographic algorithm is the message authentication code (MAC). A MAC is a data element associated with a data block or message. The MAC is generated by a cryptographic transformation involving a secret key and, typically, a cryptographic hash function of the message. The MAC is designed so that someone in possession of the secret key can verify the integrity of the message. Thus, the MAC algorithm takes as input a message and a secret key and produces the MAC. The recipient of the message plus the MAC can perform the same calculation on the message; if the calculated MAC matches the MAC accompanying the message, this provides assurance that the message has not been altered.

Two-Key Algorithms

Two-key algorithms involve the use of two related keys. A private key is known only to a single user or entity, whereas the corresponding public key is made available to a number of users. Encryption algorithms that use two related keys are referred to as *asymmetric encryption algorithms*. Asymmetric encryption can work in two ways:

- An encryption algorithm takes as input some data to be protected and the private key and produces an unintelligible transformation on that data. A corresponding decryption algorithm uses the transformed data and the corresponding public key to recover the original data. In this case, only the possessor of the private key can have performed the encryption, and any possessor of the public key can perform the decryption.
- An encryption algorithm takes as input some data to be protected and a public key and produces an unintelligible transformation on that data. A corresponding decryption algorithm uses the transformed data and the corresponding private key to recover the original data. In this case, any possessor of the public key can have performed the encryption, and only the possessor of the private key can perform the decryption.

Asymmetric encryption has a variety of applications. One of the most important is the *digital signature algorithm*. A digital signature is a value computed with a cryptographic algorithm and associated with a data object in such a way that any recipient of the data can use the signature to verify the data's origin and integrity. Typically, the signer of a data object uses the signer's private key to generate the signature, and anyone in possession of the corresponding public key can verify the validity of that signature.

Asymmetric algorithms can also be used in two other important applications. *Key exchange* is the process of securely distributing a symmetric key to two or more parties. *User authentication* is the process of authenticating that a user attempting to access an application or a service is genuine and, similarly, that the application or service is genuine.

1.6 Symmetric Encryption

Symmetric encryption, also referred to as secret-key encryption, is a cryptographic scheme in which encryption and decryption are performed using the same key. A symmetric encryption scheme has five ingredients, as illustrated in Figure 1.5:

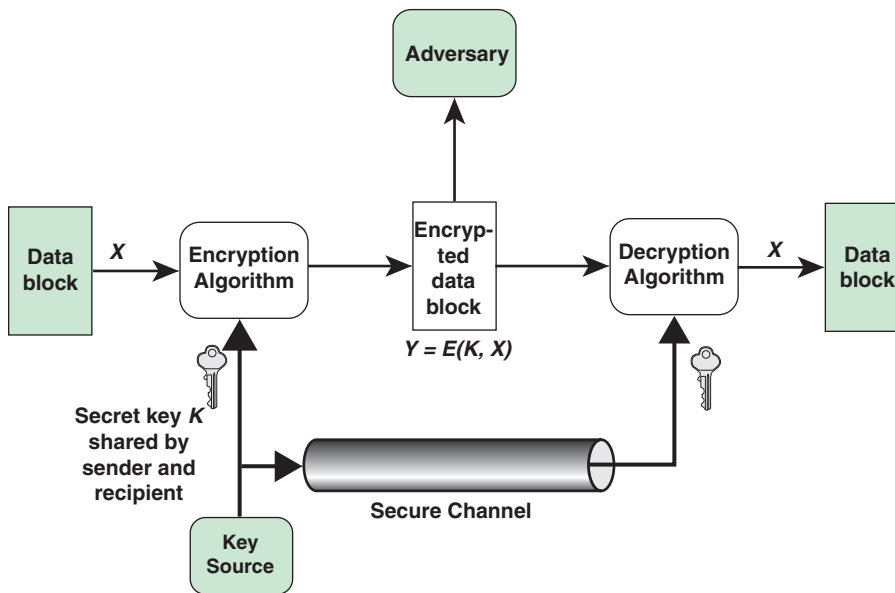


FIGURE 1.5 Model of Symmetric Cryptosystem

- **Plaintext:** The original message or data block that is fed into the algorithm as input.
- **Encryption algorithm:** The algorithm that performs various substitutions and transformations on the plaintext.
- **Secret key:** An input to the encryption algorithm. The exact substitutions and transformations performed by the algorithm depend on the key.
- **Ciphertext:** The scrambled message produced as output. It depends on the plaintext and the secret key. For a given data block, two different keys will produce two different ciphertexts.
- **Decryption algorithm:** The inverse of the encryption algorithm. It uses the ciphertext and the secret key to produce the original plaintext.

There are two requirements for secure use of symmetric encryption:

- A strong encryption algorithm is required. At a minimum, the algorithm should be such that an opponent who knows the algorithm and has access to one or more ciphertexts would be unable to decipher the ciphertext or figure out the key. This requirement is usually stated in a stronger form: The opponent should be unable to decrypt ciphertext or discover the key even if he or she is in possession of a number of ciphertexts together with the plaintext that produced each ciphertext.

- The sender and receiver must have obtained copies of the secret key in a secure fashion and must keep the key secure. If someone can discover the key and knows the algorithm, all communication using this key is readable.

The generation and distribution of secret keys are essential elements of a symmetric cryptography scheme. Typically, a key generation algorithm generates a random number and derives a secret key from that number. For two parties to communicate, there are a number of possibilities for key distribution, including:

- One party generates the key and securely transfers it to the other party.
- The two parties engage in a secure key exchange protocol that enables them to jointly generate a key known only to the two parties.
- A third party generates the key and securely transfers it to the two communicating parties.

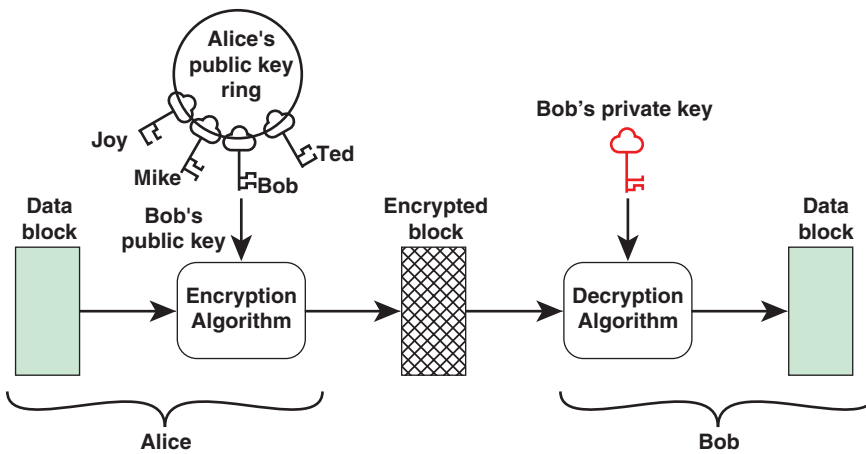
Figure 1.5 illustrates the first alternative. One way to establish a secure channel of communication is if the two parties already share an older secret key, and the party that generates the key can encrypt the new key with the older key. Another alternative is the use of public-key cryptography to encrypt the key. Public-key cryptography is discussed subsequently.

Figure 1.5 also indicates the existence of a potential adversary that seeks to obtain the plaintext. It is assumed that the adversary can eavesdrop on the encrypted data and knows the encryption and decryption algorithms that were used.

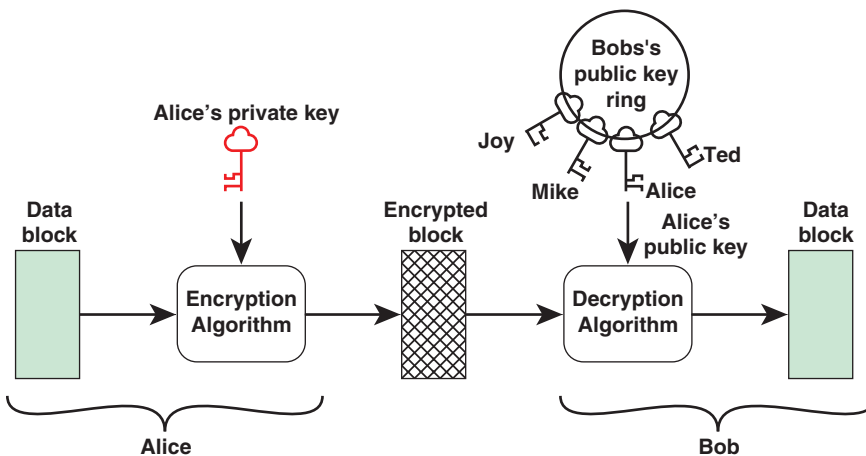
There are two general approaches an adversary can use to attack a symmetric encryption scheme. One approach is *cryptanalysis*. Cryptanalytic attacks rely on the nature of the algorithm plus perhaps some knowledge of the general characteristics of the plaintext or even some sample plaintext/ciphertext pairs. This type of attack exploits the characteristics of the algorithm to attempt to deduce a specific plaintext or to deduce the key being used. If an attack succeeds in deducing the key, the effect is catastrophic: All future and past messages encrypted with that key are compromised. The second method, known as the *brute-force attack*, involves trying every possible key on a piece of ciphertext until an intelligible translation into plaintext is obtained. On average, half of all possible keys must be tried to achieve success. Thus, a secure symmetric encryption scheme requires an algorithm that is secure against cryptanalysis and a key of sufficient length to defeat a brute-force attack.

1.7 Asymmetric Encryption

Public-key cryptography, also called *asymmetric cryptography*, involves the use of two separate keys, in contrast to symmetric encryption, which uses only one key. The use of two keys has profound consequences in the areas of confidentiality, key distribution, and authentication. A public-key encryption scheme has six ingredients (see part a of Figure 1.6; compare with Figure 1.5):



(a) Public-key encryption/decryption (Alice encrypts block for Bob only)



(b) Public-key encryption/decryption (Alice authenticates block for any recipient)

FIGURE 1.6 Model of Asymmetric Cryptosystem

- **Plaintext:** This is the readable message or data block that is fed into the algorithm as input.
- **Encryption algorithm:** The encryption algorithm performs various transformations on the plaintext.
- **Public key and private key:** This is a pair of keys that have been selected so that if one is used for encryption, the other is used for decryption. The exact transformations performed by the encryption algorithm depend on the public or private key that is provided as input.

- **Ciphertext:** This is the scrambled block produced as output. It depends on the plaintext and the key. For a given message, two different keys will produce two different ciphertexts.
- **Decryption algorithm:** This algorithm accepts the ciphertext and the matching key and produces the original plaintext.

The essential steps shown in part a of Figure 1.6 are as follows:

1. Each user generates a pair of keys to be used for the encryption and decryption of messages.
2. Each user places one of the two keys in a public register or another accessible file. This is the public key. The companion key is kept private. As part a of Figure 1.6 suggests, each user maintains a collection of public keys obtained from others.
3. If Alice wishes to send a confidential message to Bob, Alice encrypts the message using Bob's public key.
4. When Bob receives the message, he decrypts it using his private key. No other recipient can decrypt the message because only Bob knows Bob's private key.

The process works (produces the correct plaintext on output) regardless of the order in which the pair of keys is used. With this approach, all participants have access to public keys, and private keys are generated locally by each participant and therefore need never be distributed. As long as a user's private key remains protected and secret, incoming communication is secure. At any time, a system can change its private key and publish the companion public key to replace its old public key. Table 1.2 summarizes some of the important aspects of symmetric and asymmetric encryption.

TABLE 1.2 Symmetric and Asymmetric Encryption

Symmetric Encryption	Asymmetric Encryption
<i>Needed to Work:</i>	<i>Needed to Work:</i>
The same algorithm with the same secret key is used for encryption and decryption.	One algorithm is used for encryption and a related algorithm for decryption, with a pair of keys, known as the public key and the private key. The two keys can be used in either order, one for encryption and one for decryption.
The sender and receiver must share the algorithm and the secret key.	The sender and receiver must each have a unique public/private key pair.
<i>Needed for Security:</i>	<i>Needed for Security:</i>
The key must be kept secret.	The private key must be kept secret.
It must be impossible or at least impractical to decipher a message if the key is kept secret.	It must be impossible or at least impractical to decipher a message if the private key is kept secret.
Knowledge of the algorithm plus samples of ciphertext must be insufficient to determine the key.	Knowledge of the algorithm plus the public key plus samples of ciphertext must be insufficient to determine the private key.

As with symmetric encryption, asymmetric key generation involves the use of a random number. In this case, the key generation algorithm computes a private key from a random number and then computes a public key as a function of the private key. Without knowledge of the private key, it is infeasible to calculate the public key. On the other hand, knowledge of the public key does not enable calculation of the private key.

Public-key encryption can be used in another way, as illustrated in part b of Figure 1.6. Suppose that Alice wants to send a message to Bob and, although it isn't important that the message be kept secret, she wants Bob to be certain that the message is indeed from her. In this case, Alice uses her private key to encrypt the message. When Bob receives the ciphertext, he finds that he can decrypt it with Alice's public key, thus proving that the message must have been encrypted by Alice: No one else has Alice's private key, and therefore no one else could have created a ciphertext that could be decrypted with Alice's public key.

As with symmetric encryption algorithms, the security of public-key encryption is a function of the strength of the algorithm and the length of the private key. Public-key cryptographic algorithms are considerably slower than symmetric algorithms for a given data block length. Accordingly, public-key cryptography is almost always limited to use with small blocks of data, such as a secret key or, as discussed subsequently, a hash value.

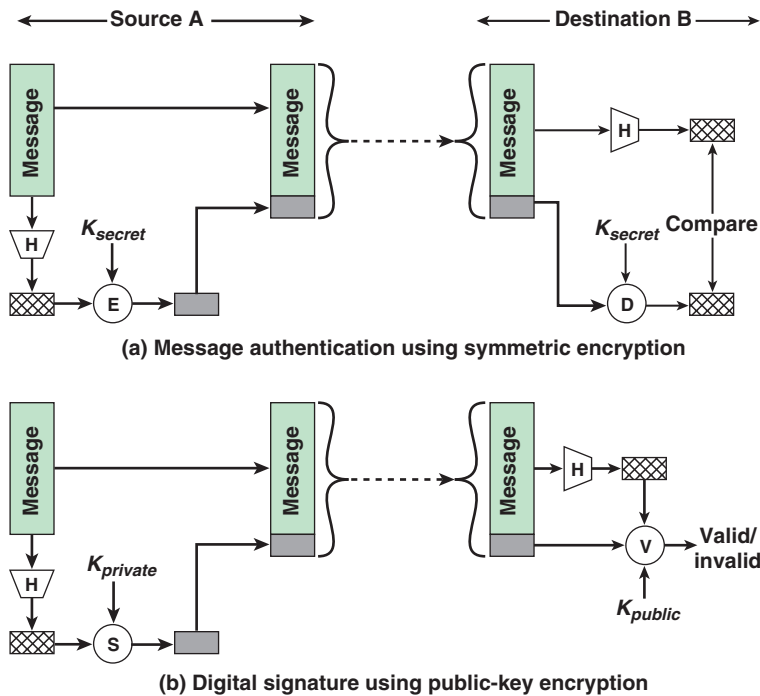
1.8 Cryptographic Hash Functions

A hash function takes an input of arbitrary length and maps it to a fixed-length data block that is typically shorter than the input data block. This is therefore a many-to-one function; that is, multiple input blocks produce the same output. The output is known as the hash value or hash digest. A cryptographic hash function, also known as a secure hash function, is a hash function with specific properties that are useful for various cryptographic algorithms, as explained subsequently. Secure hash functions are an essential element of many security protocols and applications. To be useful for security applications, a hash function called H must have the properties indicated in Table 1.3.

TABLE 1.3 Requirements for Cryptographic Hash Function H

Requirement	Description
Variable input size	H can be applied to a block of data of any size.
Fixed output size	H produces a fixed-length output.
Efficiency	$H(x)$ is relatively easy to compute for any given x , making both hardware and software implementations practical.
Preimage resistant (one-way property)	For any given hash value h , it is computationally infeasible to find y such that $H(y) = h$.
Second preimage resistant (weak collision resistant)	For any given block x , it is computationally infeasible to find $y \neq x$ with $H(y) = H(x)$.
Collision resistant (strong collision resistant)	It is computationally infeasible to find any pair (x, y) such that $H(x) = H(y)$.
Pseudorandomness	Output of H meets standard tests for pseudorandomness; that is, the output appears to be a random sequence of bits.

Figure 1.7 indicates two common ways in which hash functions are used. Part a of Figure 1.7 illustrates the use of a hash function to ensure the data integrity of a block of data, generally referred to as message authentication. The two important aspects of message authentication are to verify that the contents of the message have not been altered and that the source is authentic. The hash function can also verify a message's timeliness (to see if it has been artificially delayed and replayed) and sequence relative to other messages flowing between two parties by including timestamps and sequence numbers in the message.



E = encryption algorithm
D = decryption algorithm
H = hash function

S = signing algorithm
V = verifying algorithm

FIGURE 1.7 Uses for a Secure Hash Function

Message authentication using a hash value proceeds as follows. First, generate a hash value for the source message. Next, encrypt the hash value using a secret key shared by a cooperating partner. Then, transmit the message plus encrypted hash value to the destination. The recipient decrypts the incoming encrypted hash value, generates a new hash value from the incoming message, and compares the two hash values. If only the receiver and the sender know the identity of the secret key, and if the received code matches the calculated code, then:

- The receiver is assured that the message has not been altered. If an attacker alters the message but does not alter the code, then the receiver's calculation of the code will differ from the

received code. For a secure hash function, it is infeasible for an attacker to alter the message in such a way that the hash value is not altered.

- The receiver is assured that the message is from the alleged sender. Because no one else knows the secret key, no one else could prepare a message with a proper code.
- If the message includes a sequence number (as is used with TCP), then the receiver can be assured of the proper sequence because an attacker cannot successfully alter the sequence number.

A second important use for hash functions is in the digital signature process, explained next.

1.9 Digital Signatures

NIST FIPS 186-4 (*Digital Signature Standard*) defines a digital signature as follows:

The result of a cryptographic transformation of data that, when properly implemented, provides a mechanism for verifying origin authentication, data integrity, and signatory non-repudiation.

Thus, a digital signature is a data-dependent bit pattern, generated by an agent as a function of a file, message, or other form of data block. Another agent can access the data block and its associated signature and verify that (1) the data block has been signed by the alleged signer, and (2) the data block has not been altered since the signing. Further, the signer cannot repudiate the signature.

Part b of Figure 1.7 provides a simplified illustration of the digital signature process. Suppose that Bob wants to sign a document or message. Although it is not important that the message be kept secret, he wants others to be certain that the message is indeed from him. For this purpose, Bob uses a secure hash function to generate a hash value for the message. Together, that hash value and Bob's private key serve as input to a digital signature generation algorithm that produces a short block that functions as a digital signature. Bob sends the message with the signature attached. Any other user can calculate a hash value for the message. The user then inputs that hash value, the attached signature, and Bob's public key to a digital signature verification algorithm. If the algorithm returns the result that the signature is valid, the user is assured that the message must have been signed by Bob. No one else has Bob's private key; therefore, no one else could have created a signature that could be verified for this message with Bob's public key. In addition, it is impossible to alter the message without access to Bob's private key, so the message is authenticated both in terms of source and in terms of data integrity. The message also has the feature of nonrepudiation. Bob cannot deny having signed the message because no one else could have done so.

Digital signatures are widely used for a number of purposes, including:

- Digitally signing email messages to authenticate the sender
- Digitally signing software programs to authenticate the source of the program and to counter the threat of software tampering